
Sustentación de Evaluación

Módulo 3: Malware y Vulnerabilidades

Amenazas, Malware, APTs, Ingeniería Social y Phishing

Integrantes

Cristian Camilo Pérez Pinilla
Juan Camilo Riveros
Darlyn Julieth Pérez

Curso	Ciberseguridad — Bootcamp Betek
Módulo	3 — Malware y vulnerabilidades
Evaluación	Clase 5 — Evaluación 2
Fecha de entrega	09 / 06 / 2026
Valor total	100 puntos

Tabla de contenidos

1	Introducción y objetivo de la sustentación	3
2	Sección 1: Análisis de evidencias e identificación de amenazas (30 pts)	4
2.1	P1 — Análisis del correo bancario (10 pts)	4
2.1.1	a) Cuatro indicadores de malicia (sustentación detallada)	4
2.1.2	b) Tipo específico de phishing	4
2.1.3	c) Acciones inmediatas para Julio	4
2.2	P2 — Análisis del log de red (10 pts)	6
2.2.1	a) Tipo de amenaza y mapeo MITRE ATT&CK	6
2.2.2	b) Reconstrucción cronológica	6
2.2.3	c) Significado del acceso a LSASS y de la exfiltración	7
2.3	P3 — Análisis del SMS de la DIAN (10 pts)	8
2.3.1	a) Tipo de ataque: Smishing	8
2.3.2	b) Indicadores de Compromiso (IOC)	8
2.3.3	c) ¿Por qué es más efectivo que un email?	8
3	Sección 2: Escenarios de Ataque (25 pts)	9
3.1	P4 — Escenario A: La llamada de soporte (8 pts)	9
3.1.1	a) Técnicas de ingeniería social utilizadas	9
3.1.2	b) Etapas del ataque (mapeo a la Anatomía de Phishing y al Kill Chain)	9
3.1.3	c) Señales de alerta que Carolina debió identificar	9
3.2	P5 — Escenario B: El documento de licitación (9 pts)	10
3.2.1	a) Categoría: Amenaza Persistente Avanzada (APT)	10
3.2.2	b) Vector de entrada y mecanismo de ejecución	10
3.2.3	c) Mapeo al Cyber Kill Chain	10
3.3	P6 — Clasificación rápida (8 pts)	11
3.3.1	a) Proceso en memoria, sin archivos, HTTPS legítimo	11
3.3.2	b) SMS sobre retención de salario	11
3.3.3	c) Llamada al recepcionista por “nuevo empleado de TI”	11
4	Sección 3: Casos Reales (25 pts)	12
4.1	P7 — SolarWinds (2020) (9 pts)	12
4.1.1	a) Mecanismo de entrada y distribución	12
4.1.2	b) Por qué es difícil de detectar (relación con APT)	12
4.1.3	c) Plan CISO — primeras 48 horas	12
4.2	P8 — WannaCry (2017) (8 pts)	14
4.2.1	a) Vulnerabilidad explotada y tipo de malware	14
4.2.2	b) Impacto más allá de lo tecnológico (NHS UK)	14
4.2.3	c) Medida técnica preventiva y por qué no se aplicó	14
4.3	P9 — Twitter 2020 (8 pts)	15
4.3.1	a) Técnica de ingeniería social y empleados objetivo	15
4.3.2	b) Herramienta interna abusada e insider threat	15
4.3.3	c) Categorización principal del incidente	15
5	Sección 4: Medidas Defensivas (20 pts)	16
5.1	P10 — Plan de defensa antiphishing en capas (10 pts)	16
5.1.1	Matriz de controles propuestos	16
5.1.2	Justificación de la defensa en profundidad	17
5.2	P11 — Plan de respuesta ante APT activo (10 pts)	18

5.2.1	1. Preparación (pre-incidente)	18
5.2.2	2. Identificación	18
5.2.3	3. Contención	18
5.2.4	4. Erradicación	19
5.2.5	5. Recuperación	19
5.2.6	6. Lecciones aprendidas	19
6	Conclusiones de la sustentación	21
	Referencias del módulo	21

1. Introducción y objetivo de la sustentación

Esta sustentación tiene como objetivo argumentar, profundizar y respaldar técnicamente cada una de las respuestas entregadas en la evaluación del Módulo 3 del Bootcamp de Ciberseguridad, utilizando explícitamente los conceptos, definiciones, técnicas, herramientas y marcos vistos en las diapositivas: *Tipos de malware*, *Detección y prevención de malware*, *Técnicas de ataque de APTs*, *Técnicas de ingeniería social y Phishing*, *Escaneo de vulnerabilidades* y *Reconocimiento pasivo y activo*.

La evaluación cubre cuatro grandes ejes:

1. **Análisis de evidencias** (30 pts): identificación de amenazas a partir de correos, logs y SMS.
2. **Escenarios de ataque** (25 pts): clasificación de técnicas, vectores y fases.
3. **Casos reales** (25 pts): SolarWinds (2020), WannaCry (2017) y el incidente de Twitter (2020).
4. **Medidas defensivas** (20 pts): diseño de controles antiphishing y plan de respuesta a incidentes ante una APT.

Marcos de referencia utilizados

A lo largo del documento se hace referencia al **Cyber Kill Chain** (Lockheed Martin), al marco **MITRE ATT&CK** (tácticas TA0001 Initial Access, TA0002 Execution, TA0003 Persistence, TA0008 Lateral Movement, TA0010 Exfiltration, TA0011 Command and Control, TA0043 Reconnaissance), al sistema **CVE/CVSS v3** y a los principios de **Defensa en Profundidad** y **Mínimo Privilegio**.

2. Sección 1: Análisis de evidencias e identificación de amenazas (30 pts)

2.1 P1 — Análisis del correo bancario (10 pts)

Resumen del caso

Un empleado recibe un correo desde `seguridad@banco-colombia-corp.net` (dominio no oficial) que le exige verificar su cuenta en menos de 2 horas mediante un enlace que apunta a `banco-colombia-corp.net.verify-account.ru/login?token=XF7K2`.

2.1.1 a) Cuatro indicadores de malicia (sustentación detallada)

Conforme a la sección *Señales de Alerta* de la diapositiva de Phishing y al *Catálogo de Ataques* (Clase 4), se identificaron los siguientes indicadores:

1. **Dominio sospechoso del remitente.** El dominio `banco-colombia-corp.net` no corresponde al dominio oficial del banco. Las diapositivas señalan el patrón de *typosquatting* (dominios visualmente similares, p. ej. `micr0soft.com`). Aquí se añade una palabra (*corp*) y se cambia el TLD legítimo (`.com.co` → `.net`) para inducir confianza.
2. **URL manipulada y enmascarada.** El enlace usa la técnica de *subdominio engañoso*: `banco-colombia-corp.net` aparece como *subdominio* de `verify-account.ru`. El dominio real (lo que controla el atacante) es `verify-account.ru`, en Rusia. Esto coincide con lo enseñado: “hover sobre el link muestra una dirección diferente al texto”.
3. **Urgencia artificial (factor psicológico).** “Próximas 2 horas” y “bloqueo definitivo” activan el principio de **Urgencia** del catálogo de manipulación psicológica (Clase 4), diseñado para impedir el pensamiento crítico.
4. **Solicitud de credenciales fuera del proceso oficial.** Un banco nunca solicita restablecer contraseñas mediante un enlace en correo. Esto rompe el control de *verificación fuera de banda* recomendado en la diapositiva de defensa.

2.1.2 b) Tipo específico de phishing

Se clasificó como **Spear Phishing** (T1566.001 en MITRE ATT&CK). La justificación: el correo está *dirigido a una persona concreta* (Julio Martínez) con datos contextuales (cuenta corporativa, IP supuestamente externa). En las diapositivas se diferencia explícitamente: “*Spear phishing* — ataque dirigido y personalizado contra una persona u organización específica. Muy efectivo”, mientras que el *Email Phishing* masivo es genérico (“Estimado cliente”).

2.1.3 c) Acciones inmediatas para Julio

Siguiendo el principio “*Si dudas, reporta*” y la doctrina de *verificación fuera de banda*:

- No hacer clic en el enlace ni descargar adjuntos (evita exploits del navegador / payloads).
- Reportar al equipo de seguridad (SOC) por el canal interno definido. Esto activa el flujo de respuesta a incidentes (fase de Identificación).
- Verificar mediante **canal oficial** (app del banco, línea de atención impresa en la tarjeta, sitio web tecleado manualmente).
- Preservar el correo con cabeceras completas para análisis forense (extracción de IOC: IP de origen, SPF/DKIM/DMARC, hashes de adjuntos).

IOC potenciales que debería extraer el SOC

Dominio `banco-colombia-corp.net`; dominio real `verify-account.ru`; IP `185.220.101.47` (rango conocido de nodos Tor); patrón de asunto “URGENTE - Actividad inusual”.

2.2 P2 — Análisis del log de red (10 pts)

Resumen del caso

Se observa una secuencia de eventos en un endpoint donde `svchost.exe` establece una conexión saliente, resuelve un dominio DDNS, crea un binario en `AppData\Roaming`, modifica la clave `Run` del registro, lanza PowerShell ofuscado, accede a LSASS y exfiltra 2.3 MB.

2.2.1 a) Tipo de amenaza y mapeo MITRE ATT&CK

Se trata de un **RAT (Remote Access Trojan)** / **infostealer** con capacidades de Comando y Control (C2). El patrón “acceso a LSASS + PowerShell ofuscado + persistencia `Run` + exfiltración HTTPS” es consistente con frameworks como *Cobalt Strike*, *Sliver*, *Brute Ratel* o agentes tipo *Empire*, todos mencionados en la Clase 3 (APTs).

Mapeo MITRE ATT&CK paso a paso

- T1071.004 — *Application Layer Protocol: DNS*. Consulta a `c2panel-eu.ddns.net` (DDNS típico de C2 de bajo costo).
- T1036.005 — *Masquerading: Match Legitimate Name or Location*. `winupd.exe` imita una actualización de Windows.
- T1547.001 — *Boot or Logon Autostart Execution: Registry Run Keys*. Persistencia en `HKCU\...\Run\WinUpdate`.
- T1059.001 — *Command and Scripting Interpreter: PowerShell*. Ejecución con `-enc` (Base64), técnica de ofuscación clásica.
- T1003.001 — *OS Credential Dumping: LSASS Memory*. Volcado tipo *Mimikatz*.
- T1041 — *Exfiltration Over C2 Channel*. 2.3 MB salientes por 443/TCP.

2.2.2 b) Reconstrucción cronológica

La línea de tiempo refleja una intrusión típica post-explotación. En menos de 30 segundos el actor pasa de C2 a robo de credenciales y exfiltración, lo cual es consistente con un *beacon* pre-configurado:

1. **02:17:43** — Conexión saliente desde `svchost.exe` (PID 4821) a `91.195.240.94:443`. Indica *process hollowing* o *DLL injection* en un binario legítimo de Windows. Este patrón se enseña en la Clase 3 como “Proceso hijo anómalo”.
2. **02:17:44** — Consulta DNS a `c2panel-eu.ddns.net`. El uso de DDNS es bandera roja: infraestructura desechable, rotación rápida.
3. **02:17:46** — Creación de `C:\Users\AppData\Roaming\winupd.exe` — *dropper* colocando el implante (T1105 Ingress Tool Transfer).
4. **02:17:47** — Persistencia en clave `Run`. El malware sobrevivirá al reinicio.
5. **02:18:02** — PowerShell con `-enc` (Base64). Ejecución en memoria — característica de *fileless* o *stagers*.
6. **02:18:05** — Acceso a LSASS desde `winupd.exe`. *Credential dumping*. Detectable por *Sysmon Event 10* (handle a `lsass.exe`).
7. **02:18:09** — Exfiltración de 2.3 MB sobre 443. Tráfico mimetizado con HTTPS legítimo.

2.2.3 c) Significado del acceso a LSASS y de la exfiltración

LSASS (*Local Security Authority Subsystem Service*) almacena en memoria los *secretos de autenticación*: hashes NTLM, tickets Kerberos (TGT/TGS) y, en escenarios mal configurados, contraseñas en texto claro (caché WDigest). El acceso indica que se ejecutó algo equivalente a `mimikatz sekurlsa::logonpasswords` o `sekurlsa::pth`. La exfiltración de 2.3 MB es coherente con un volcado de credenciales y artefactos del directorio activo. El riesgo subsecuente es **movimiento lateral** mediante *Pass-the-Hash* (T1550.002), *Pass-the-Ticket* (T1550.003) o incluso *Golden Ticket* (T1558.001) si el atacante captura el hash de la cuenta KRBTGT.

2.3 P3 — Análisis del SMS de la DIAN (10 pts)

Resumen del caso

SMS desde un número no oficial (+57 301 555 8821) que suplanta a la DIAN, anuncia una multa de \$3.450.000 e incluye el enlace `dian-gov-co.verificar.xyz/contribuyente`.

2.3.1 a) Tipo de ataque: Smishing

Es **Smishing** (SMS Phishing), T1660 en MITRE ATT&CK. Es una subclase de ingeniería social que combina los principios de **Autoridad** (suplantar la DIAN) y **Urgencia/Miedo** (multa y embargo). En las diapositivas se define como “SMS con enlace malicioso o solicitud urgente”.

2.3.2 b) Indicadores de Compromiso (IOC)

- Número remitente no oficial (la DIAN comunica desde códigos cortos institucionales o desde `.gov.co`).
- Dominio `dian-gov-co.verificar.xyz` — el dominio real es `verificar.xyz`, no `dian.gov.co`. TLD `.xyz` es típicamente abusado por su bajo costo.
- Errores de redacción (tildes faltantes en “detecto”, “declaracion”). Es una bandera roja en la lista de la Clase 4.
- Suplantación de identidad gubernamental (T1656 Impersonation).
- Llamada a una acción urgente (“evite embargo”).

2.3.3 c) ¿Por qué es más efectivo que un email?

Las diapositivas explican por qué el factor humano es “el sistema operativo” atacado. En el caso del SMS:

- **Confianza ciega en el canal SMS.** Históricamente se ha usado para OTP bancarios y alertas oficiales.
- **Falta de filtros antispam efectivos en operadores móviles**, equivalentes a los de correo (SPF/DKIM/DMARC).
- **Pantalla pequeña.** La URL maliciosa se ve truncada; el usuario no inspecciona el dominio completo.
- **Inmediatez psicológica.** El SMS se lee en segundos; la urgencia del mensaje refuerza el impulso de clic.

3. Sección 2: Escenarios de Ataque (25 pts)

3.1 P4 — Escenario A: La llamada de soporte (8 pts)

Caracterización del ataque

Combinación de **Vishing** (T1598.004 — voice phishing) + **Pretexting** (T1598) + abuso de software legítimo de control remoto (TeamViewer).

3.1.1 a) Técnicas de ingeniería social utilizadas

Conforme al *Catálogo de Ataques* (Clase 4):

- **Autoridad.** El atacante se presenta como “técnico de Microsoft”. La diapositiva define: “*Imitar a una figura de poder: jefe, banco o soporte IT*”.
- **Urgencia.** “Si no actúa ahora, perderá todos sus archivos” — diseñada para anular el pensamiento crítico (factor psicológico número 2).
- **Pretexting.** Construcción de una historia completa y coherente (“detectamos un virus”) con identidad falsa convincente.
- **Reciprocidad.** Al “ayudarla” con el diagnóstico, el atacante crea una obligación social que facilita la solicitud posterior (datos de tarjeta).

3.1.2 b) Etapas del ataque (mapeo a la Anatomía de Phishing y al Kill Chain)

Según la anatomía vista en clase (5 fases para phishing y 7 para APT):

- **Reconocimiento** — el atacante perfila a Carolina (su rol en contabilidad, redes sociales, OSINT).
- **Preparación (Armado)** — guion telefónico, número spoofeado, URL de descarga de TeamViewer falso o legítimo.
- **Distribución / Entrega** — llamada telefónica entrante (vishing).
- **Explotación** — Carolina instala TeamViewer y entrega control.
- **Exfiltración / Acciones sobre objetivos** — robo de datos de tarjeta de crédito.

3.1.3 c) Señales de alerta que Carolina debió identificar

- **Urgencia artificial.** “Virus grave” + “perderá archivos”.
- **Remitente no verificable.** Microsoft no realiza llamadas proactivas a usuarios finales para diagnóstico de virus.
- **Petición fuera de proceso.** El soporte IT corporativo es el canal oficial; jamás un técnico externo solicitaría pago por tarjeta para “limpiar un virus”.
- **Software ajeno al inventario corporativo.** Instalar TeamViewer por petición externa viola política de *Software Authorized List*.

3.2 P5 — Escenario B: El documento de licitación (9 pts)

3.2.1 a) Categoría: Amenaza Persistente Avanzada (APT)

Conforme a la Clase 3, una APT se define por la triada **A**dvanced + **P**ersistent + **T**hreat. El caso reúne todas las características:

- **Advanced.** Spear phishing con documento Word + macros maliciosas (técnica sofisticada y dirigida).
- **Persistent.** 45 días sin alarma — el tiempo promedio de detección de una APT es 287 días según el “IBM Cost of a Data Breach Report 2024”.
- **Threat.** Actor con objetivo claro (sector energético = infraestructura crítica), recursos y motivación (espionaje o sabotaje).
- **Movimiento lateral** hacia servidores de producción.
- **C2** con comunicaciones cifradas a IPs en el extranjero.
- **Exfiltración** de bases de datos a carpeta oculta antes del envío externo.

3.2.2 b) Vector de entrada y mecanismo de ejecución

Vector inicial: Spear phishing (T1566.001) con adjunto `.docx`. La diapositiva ya advertía: “IoCs: dominios typosquatting, adjuntos `.docm`, macros VBA”.

Mecanismo: Al habilitar macros, el documento ejecuta código VBA → invoca `cmd.exe` / `powershell.exe` → descarga el implante. Este encadenamiento (*Word* → *cmd* → *PowerShell*) es justamente el patrón “Proceso hijo anómalo” marcado como señal clave de detección por la regla `Sigma proc_creation_win_susp_child_process.yml`.

3.2.3 c) Mapeo al Cyber Kill Chain

Fase del Kill Chain	¿Aplica?	Evidencia en el escenario
Reconocimiento (TA0043)	Sí	Identificación del Director de Tecnología como objetivo de alto valor; uso probable de LinkedIn y OSINT.
Armado (Weaponization)	Sí	Creación del documento <code>Propuesta_Licitacion_2024.docx</code> con macro VBA maliciosa.
Entrega (TA0001)	Sí	Correo plausible de una “firma consultora”.
Explotación (TA0002)	Sí	La víctima habilita macros; se ejecuta VBA → PowerShell.
Instalación (TA0003)	Sí	Persistencia durante 45 días; presumiblemente Registry Run Keys o Scheduled Tasks.
C&C (TA0011)	Sí	Comunicaciones cifradas a IPs externas (típicamente HTTPS/TLS o DNS tunneling).
Acciones sobre objetivos / Exfiltración (TA0010)	Sí	Copia de bases de datos a carpeta oculta y posterior extracción.

Principio clave reforzado

“Interrumpir el Kill Chain en cualquier fase es suficiente para frustrar el ataque”. En este caso, bloquear las macros por GPO o desplegar EDR habría cortado el ataque en la fase de Explotación.

3.3 P6 — Clasificación rápida (8 pts)

3.3.1 a) Proceso en memoria, sin archivos, HTTPS legítimo

Fileless Malware. La Clase 1 (Tipos de malware) y la Clase 3 (APT) cubren esta categoría. Características:

- No toca disco — vive en RAM, evita el AV basado en firmas.
- Usa binarios *Living off the Land* (LOLBins): PowerShell, WMI, mshta, regsvr32.
- Tráfico de C2 mezclado con tráfico legítimo (T1071.001 HTTPS).

3.3.2 b) SMS sobre retención de salario

Smishing (T1660). Combina *urgencia emocional* (salario retenido) + suplantación de entidad bancaria + URL fraudulenta. Patrón idéntico al P3 con el twist financiero/laboral.

3.3.3 c) Llamada al recepcionista por “nuevo empleado de TI”

Vishing + Pretexting (T1598.004 + T1598). Es exactamente el patrón usado contra MGM Resorts en 2023 por Scattered Spider: identificación de la víctima vía LinkedIn → llamada al helpdesk → solicitud de acceso. El helpdesk, como afirma la diapositiva, es uno de los vectores más vulnerables: “entrenado para ayudar, no para desconfiar”.

4. Sección 3: Casos Reales (25 pts)

4.1 P7 — SolarWinds (2020) (9 pts)

Datos clave

Ataque atribuido a APT29 / Cozy Bear (Rusia, SVR). Backdoor SUNBURST insertado en una actualización legítima de *SolarWinds Orion*. Más de 18.000 organizaciones afectadas, incluidas agencias federales de EE.UU.

4.1.1 a) Mecanismo de entrada y distribución

Categoría: *Supply Chain Attack* (T1195, técnica de *Initial Access*).

Entrada: Los atacantes comprometieron el *build system* (entorno de compilación de SolarWinds), inyectando el backdoor SUNBURST dentro del binario `SolarWinds.Orion.Core.BusinessLayer.dll`.

Distribución: La actualización maliciosa se distribuyó por los canales oficiales y **firmada digitalmente** por SolarWinds. Esto vuelve invisible al ataque para los controles basados en confianza del fabricante (Whitelisting, AppLocker, etc.).

Activación: SUNBURST esperaba entre 12–14 días antes de activarse, consultaba un subdominio de `avsvmcloud.com` para C2 y solo se activaba en objetivos seleccionados.

4.1.2 b) Por qué es difícil de detectar (relación con APT)

- **Confianza en la cadena de suministro.** El binario está firmado por una CA legítima.
- **Persistencia y bajo perfil.** Periodos de espera (dormancy), evasión de sandboxes y selección quirúrgica de objetivos.
- **C2 enmascarado.** Uso de algoritmos DGA (*Domain Generation Algorithm*) sobre el dominio `avsvmcloud.com`.
- **Movimiento lateral con credenciales legítimas** (Pass-the-Hash, Golden Ticket).
- **Objetivos específicos:** agencias gubernamentales, think tanks, Fortune 500 — coherente con el perfil de APT29.

4.1.3 c) Plan CISO — primeras 48 horas

1. **Aislamiento** de servidores Orion (no apagar — preservar memoria volátil para forense).
2. **Activación del IRP** (Plan de Respuesta a Incidentes); convocatoria CSIRT, dirección y legal.
3. **Verificación de versión.** ¿Se instaló alguna de las versiones afectadas (2019.4 HF5 a 2020.2.1)?
4. **Threat hunting con los IOC publicados:** hashes de DLL, conexiones a `avsvmcloud.com`, anomalías en SAML.
5. **Reset de credenciales privilegiadas** (Domain Admins, KRBTGT — dos rotaciones), especialmente las usadas por Orion.
6. **Bloqueo perimetral** de IPs/dominios de C2 en firewall, NGFW, IPS y EDR.
7. **Preservación forense:** memoria, logs, imágenes de disco.
8. **Notificación obligatoria** a entes regulatorios (en Colombia: SIC para datos personales; CCOC; ColCERT).

9. **Comunicación interna y externa** coordinada con legal y PR.

4.2 P8 — WannaCry (2017) (8 pts)

4.2.1 a) Vulnerabilidad explotada y tipo de malware

Vulnerabilidad: CVE-2017-0144 en el protocolo SMBv1 de Microsoft, conocida como *EternalBlue*. Corregida por el boletín **MS17-010** (marzo de 2017) — dos meses antes del brote masivo.

Tipo: **Ransomware con capacidad de gusano (worm)**. Cumple las dos definiciones de la Clase 1:

- *Ransomware*: cifra archivos con AES + RSA y solicita rescate en Bitcoin.
- *Gusano*: se autorreplica por red sin interacción del usuario, propagándose mediante SMB.

Propagación sin interacción:

1. T1046 Network Service Discovery — escanea puerto 445/TCP en la red local y subredes aleatorias.
2. TA0008 Lateral Movement — explota EternalBlue (*remote code execution* sin autenticación) para ejecutar el payload en cada host vulnerable.
3. T1486 Data Encrypted for Impact — cifrado masivo de archivos del usuario.

4.2.2 b) Impacto más allá de lo tecnológico (NHS UK)

El ataque al NHS muestra que el ciberriesgo es **riesgo operacional y humano**, no solo tecnológico:

- Cancelación de cirugías y consultas — riesgo directo a la salud y la vida.
- Pérdida de acceso a historias clínicas — toma de decisiones médicas a ciegas.
- Pérdidas económicas estimadas en £92M para el NHS.
- Cae la confianza pública en servicios esenciales.
- Subraya la dependencia de la sociedad de sistemas críticos (*Critical Infrastructure*: salud, energía, agua, transporte).

4.2.3 c) Medida técnica preventiva y por qué no se aplicó

Medida: Aplicar el parche **MS17-010** y deshabilitar SMBv1 (protocolo obsoleto). Adicionalmente: segmentación de red para que SMB no sea ruteable entre VLANs.

Por qué no se aplicó en muchas organizaciones:

- *Gestión de parches inmadura*: sin inventario actualizado ni SLAs (las diapositivas de Escaneo de Vulnerabilidades indican: “*crítica + expuesta a internet: parchear en < 72 horas*”).
- *Equipos legacy* con SO sin soporte (Windows XP, Server 2003) — el NHS UK aún operaba miles de XP.
- *Temor a romper aplicaciones críticas* sin entornos de prueba previos.
- *Falta de visibilidad*: sin escaneos de vulnerabilidades periódicos no se sabe qué hay que parchear.

Lección de gestión de vulnerabilidades (Clase 5)

EternalBlue figuró en la *CISA Known Exploited Vulnerabilities Catalog* (KEV). La diapositiva enseña: “Crítica + explotada activamente → parchear inmediatamente”. La existencia de un parche *dos meses antes* es la prueba de que el problema fue de *proceso*, no de *tecnología*.

4.3 P9 — Twitter 2020 (8 pts)

4.3.1 a) Técnica de ingeniería social y empleados objetivo

Técnica: *Vishing + Pretexting* (T1598.004 + T1598). Los atacantes llamaron a empleados haciéndose pasar por el equipo de TI interno, solicitando credenciales para resolver un “problema técnico urgente”.

Empleados objetivo: personal de **soporte y atención al cliente**, no ingenieros de seguridad. Razón: tenían acceso a herramientas internas con permisos amplios pero menor entrenamiento en concienciación de seguridad. Confirma la tesis vista en clase: el atacante busca “*el eslabón más fácil*”, no necesariamente al usuario más privilegiado.

4.3.2 b) Herramienta interna abusada e insider threat

Los atacantes accedieron a la herramienta interna conocida como “*Agent Tools*” de Twitter, que permitía: resetear contraseñas, cambiar correos asociados, reasignar 2FA, activar funciones especiales. Una vez dentro, controlaron cuentas verificadas (Obama, Biden, Musk, Apple) y lanzaron una estafa de Bitcoin que recaudó cerca de US\$120K.

Insider threat: La Clase 4 lo define como “alguien con acceso legítimo al sistema causa daño, ya sea intencional o porque fue engañado”. En Twitter 2020 fue un *insider involuntario*: las acciones provenían de cuentas reales con permisos reales, por lo que los controles de detección basados en anomalías de acceso no se dispararon. Esto se conoce como *compromised insider*, una de las tres tipologías clásicas (junto a malicioso y negligente).

4.3.3 c) Categorización principal del incidente

Principalmente: Ingeniería Social (concretamente vishing + pretexting), por las siguientes razones:

- **No es malware:** no hubo virus, exploit, ni payload ejecutado.
- **No es APT:** la operación no fue prolongada en el tiempo, ni atribuible a un actor estado-nación.
- **No es phishing tradicional:** no hubo correo masivo ni enlace falso.
- **Sí es ingeniería social:** manipulación psicológica directa, abuso de confianza, suplantación de identidad (T1656).

Refuerza la conclusión central de la Clase 4: “*9 de cada 10 brechas empiezan con una persona, no con una vulnerabilidad técnica*”.

5. Sección 4: Medidas Defensivas (20 pts)

5.1 P10 — Plan de defensa antiphishing en capas (10 pts)

Modelo aplicado: Defensa en Profundidad

El enfoque es proteger “ningún control único basta”. Si una capa falla, otra debe contener el ataque. Para phishing combinamos seis capas: técnica (correo), técnica (endpoint), red, humana, política y detección/respuesta.

5.1.1 Matriz de controles propuestos

Capa	Control	Cómo mitiga
Técnica — Correo	DMARC + SPF + DKIM en política estricta (<i>reject</i>) y Secure Email Gateway (M365 Defender, Proofpoint o equivalente) con sandbox de adjuntos.	Reduce <i>spoofing</i> de dominio y bloquea correos suplantando entidades. Detona adjuntos sospechosos en sandbox antes de entregarlos al usuario.
Técnica — Endpoint	EDR/XDR (CrowdStrike, SentinelOne o Defender for Endpoint) + bloqueo de macros de Internet por GPO + <i>Attack Surface Reduction Rules</i> .	Detecta cadenas anómalas (Word → PowerShell), bloquea macros maliciosas y aplica <i>exploit protection</i> . Si el filtro de correo falla, esta capa contiene la ejecución.
Red / Perímetro	Filtrado DNS (Cisco Umbrella, Quad9) y Web Proxy con TLS inspection + bloqueo de dominios recién registrados (<i>Newly Registered Domains</i>).	Impide que el clic en un enlace de phishing complete la conexión al sitio fraudulento. Los dominios recién registrados son típicos del phishing.
Humana	Campañas de phishing simulado trimestrales + entrenamiento basado en escenarios + botón “Reportar Phishing” en Outlook.	Convierte al usuario en sensor del SOC. La diapositiva: “el tiempo entre el primer contacto y el reporte es la ventana del atacante”.
Proceso / Política	Política de verificación fuera de banda para pagos, cambios de cuentas y transferencias + flujo de <i>four-eyes principle</i> .	Detiene fraudes BEC (<i>Business Email Compromise</i>) aunque el correo se vea legítimo.
Detección / Respuesta	SIEM (Sentinel, Splunk) con reglas Sigma + SOAR para playbooks automáticos (aislar host, bloquear hash, invalidar sesiones).	Permite identificar correos similares en otras bandejas y contener un usuario comprometido en minutos en vez de horas.

5.1.2 Justificación de la defensa en profundidad

Cada capa ataca una fase distinta de la *Anatomía del Ataque* vista en clase: la capa de correo corta la **Distribución**; el filtrado DNS corta el **Acceso al sitio fraudulento**; el EDR corta la **Explotación**; la capa humana corta la **Explotación** antes del clic; la política corta la **Acción objetivo** (transferencia fraudulenta); y el SIEM+SOAR cubre la **Detección y contención**. Ninguna capa es perfecta, pero su composición eleva exponencialmente el costo de un ataque exitoso. Adicionalmente, el control humano es el de mayor retorno: un empleado entrenado vale más que cualquier herramienta (*cita de la Clase 4*).

5.2 P11 — Plan de respuesta ante APT activo (10 pts)

Modelo aplicado: NIST SP 800-61r2 — Incident Response Lifecycle

Preparación → Identificación (Detection & Analysis) → Contención (Containment) → Erradicación → Recuperación → Lecciones Aprendidas. Es el ciclo estándar de la industria.

5.2.1 1. Preparación (pre-incidente)

Esta fase es *de paz*: ocurre antes del incidente. Incluye:

- Plan de Respuesta a Incidentes (IRP) documentado y probado anualmente.
- CSIRT con roles RACI definidos (Incident Commander, Forensics, Comms, Legal).
- Stack de detección recomendado (Clase 3): **Sysmon** + **WEF** para telemetría, **SIEM** (Sentinel/Splunk/Elastic), reglas **Sigma**, **EDR**, **Threat Intel** (MISP, feeds STIX/TAXII).
- Inventario CMDB de activos, usuarios y privilegios.
- Política de **mínimo privilegio** y **MFA resistente a phishing** (FIDO2/Passkeys).
- Copias de seguridad inmutables (regla 3-2-1-1-0).
- Segmentación de red y *Network Access Control*.
- Acuerdos con un *Incident Response Retainer* externo.

5.2.2 2. Identificación

A las 9:15 AM el SOC observa: (a) conexiones a IPs externas desconocidas, (b) CPU anómalo, (c) creación de usuarios administradores nuevos. Para confirmar:

- Correlacionar eventos del **SIEM** y **EDR** en los 3 equipos.
- Auditoría de **Event ID 4720** (creación de cuenta) y **4732** (adición a grupo administrador).
- Análisis de los procesos que consumen CPU (*hash* en VirusTotal, comparación con baselines).
- Geolocalización y reputación de las IPs externas (*AbuseIPDB*, *Threat Intel*).
- Búsqueda de IOC conocidos (dominios, hashes, mutexes).
- Verificación de **Event ID 4624 Type 3** (login de red SMB) buscando movimiento lateral.

La concurrencia de los tres síntomas en tres equipos distintos es coherente con una APT en fase de **Movimiento Lateral / Persistencia**, no con una falsa alarma.

5.2.3 3. Contención

Acciones inmediatas:

- **Aislar** los 3 equipos de la red (acción nativa del EDR o cuarentena de NAC).
- **Deshabilitar** los usuarios administradores creados; **revocar** sesiones Kerberos / OAuth activas.
- **Bloquear** las IPs/dominios externos en firewall, proxy y DNS.
- **Rotar** contraseñas de cuentas privilegiadas y, si hay sospecha de *Golden Ticket*, rotar la cuenta **KRBtgt dos veces** (el ticket se invalida al segundo cambio).
- Aumentar **telemetría** (subir el logging level de Sysmon, activar Process Auditing 4688).

¿**Apagar los equipos?** **No.** El apagado destruye la memoria RAM, donde residen artefactos críticos para la atribución: procesos inyectados, claves de cifrado, conexiones de red activas, beacons C2. La práctica forense correcta es *aislar manteniendo encendido* y capturar imagen de memoria (WinPMEM, DumpIt) antes de cualquier reinicio. Solo se apaga si hay riesgo inminente de exfiltración masiva que no pueda contenerse por red.

5.2.4 4. Erradicación

Una APT instala **múltiples mecanismos de persistencia** (Run Keys, Scheduled Tasks, WMI Subscriptions, DLL Hijacking, Web Shells). La erradicación parcial garantiza el regreso del atacante. Pasos:

- Análisis forense de los 3 equipos (memoria + disco) para enumerar TODOS los TTP usados.
- Eliminación de cuentas creadas, tareas programadas, claves de registro, servicios y *web shells*.
- Búsqueda de *lateral movement* a otros hosts no detectados; *threat hunting* con *BloodHound* sobre el AD.
- Aplicación de parches (foco en CVE de la KEV de CISA).
- Rotación masiva de credenciales: usuarios privilegiados, cuentas de servicio, certificados, secretos en bóveda (Vault/Key Vault).
- Reglas Sigma adicionales convertidas a queries KQL/SPL.

5.2.5 5. Recuperación

- **Reimagen** de los hosts comprometidos desde *golden images* verificadas.
- Restauración de datos desde **backups verificados como limpios** (anteriores a la fecha de compromiso).
- Validación de integridad mediante hashing y comparación con *baseline*.
- Reintegración *gradual* a la red con monitoreo intensivo durante 30–90 días.
- Definición de *health checks* continuos (proceso parent-child, conexiones salientes, accesos a LSASS).

5.2.6 6. Lecciones aprendidas

Para que el incidente no se repita y para mejorar el programa de seguridad:

- **Post-mortem sin culpa** (blameless) con análisis de causa raíz (5-Whys, Ishikawa).
- Actualizar *Detection Rules* con los IOC y TTPs descubiertos; alimentar la plataforma de Threat Intel.
- Fortalecer monitoreo SIEM/EDR; adoptar **MFA FIDO2** en cuentas privilegiadas.
- Aplicar **Mínimo Privilegio** y *Just-in-Time Access* con PAM.
- Segmentación adicional (microsegmentación si es viable).
- Auditorías de cuentas privilegiadas y *Active Directory tiering*.
- Programa continuo de **Red Team / Purple Team** y **Tabletop Exercises**.
- Capacitación de usuarios sobre el vector inicial usado.

Principio rector

El objetivo final no es restaurar los sistemas; es *eleva la postura de seguridad* para que el mismo TTP no funcione la próxima vez.

6. Conclusiones de la sustentación

1. **El factor humano sigue siendo el vector dominante.** El 36% de las brechas y prácticamente todos los casos estudiados (RSA, Uber, Twitter, MGM) comienzan en una persona. La defensa más rentable es la **cultura de seguridad**: entrenamiento, simulacros y un canal de reporte sin penalizar.
2. **Las APTs no son “mejor malware”; son *procesos* sofisticados.** Su característica distintiva es la **persistencia silenciosa** y el uso del **Cyber Kill Chain** completo. Interrumpir *una* fase basta para frustrar la operación; cuanto antes, mejor.
3. **MITRE ATT&CK es el idioma común.** Cada técnica vista (T1566, T1547.001, T1059.001, T1003.001, T1041, T1195, T1660...) ofrece detecciones medibles. Mapear TTPs a controles concretos es la columna vertebral del moderno *Detection Engineering*.
4. **La gestión de vulnerabilidades no es opcional.** WannaCry demostró que un parche disponible 60 días antes habría evitado pérdidas billonarias en salud pública. El proceso debe combinar escaneo, priorización por CVSS+contexto, SLAs y verificación.
5. **Defensa en profundidad sigue siendo la mejor arquitectura.** Combinar capas técnicas (correo, endpoint, red), capas humanas (entrenamiento, reporte) y capas de proceso (verificación fuera de banda, mínimo privilegio) es la única estrategia robusta frente a adversarios reales.
6. **Respuesta a incidentes es disciplina, no improvisación.** Preparación + Identificación + Contención + Erradicación + Recuperación + Lecciones Aprendidas no es un ritual: es lo que separa horas de impacto de meses de crisis.

Cita de cierre (Clase 4):

“La mejor defensa contra el phishing es el conocimiento y la vigilancia constante.”

Referencias del módulo

- Diapositivas Módulo 3, Clase 1: *Tipos de malware*.
- Diapositivas Módulo 3, Clase 2: *Detección y prevención de malware*.
- Diapositivas Módulo 3, Clase 3: *Técnicas de ataque de APTs*.
- Diapositivas Módulo 3, Clase 4: *Técnicas de ingeniería social y Phishing*.
- Diapositivas Módulo 3, Clase 5: *Escaneo de vulnerabilidades* (Diego Adrián Castaño).
- Diapositivas Módulo 3, Clase 6: *Reconocimiento pasivo y activo*.
- MITRE ATT&CK Framework, <https://attack.mitre.org>.
- CISA Known Exploited Vulnerabilities Catalog (KEV).
- IBM Cost of a Data Breach Report 2024.
- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide.
- Ley 1273 de 2009 (Colombia) — Delitos Informáticos.